

MF0487_3 - AUDITORIA DE SEGURIDAD INFORMATICA

LABORATORIO 4b

Burp Suite y OWASP ZAP

Burp Suite Community Edition	OWASP ZAP (Zed Attack Proxy)
<i>Proxy de intercepcion manual</i>	<i>Escaner automatico + proxy</i>

Objetivo: Proxy de intercepcion HTTP | Intercepcion manual | Spider y escaneo activo | Analisis comparativo

Entorno: Kali Linux Purple + Metasploitable 2 + Firefox ESR | Objetivo: DVWA

AVISO LEGAL: Todo el trafico interceptado en este laboratorio pertenece al entorno de practicas. La intercepcion o modificacion de comunicaciones sin autorizacion previa constituye un delito tipificado en el art. 197 delCodigo Penal espanol y el art. 5 del Convenio de Budapest.

0. FICHA TECNICA

Codigo	LAB-04b	UDs	UD3, UD6
Titulo	Introduccion a Burp Suite y OWASP ZAP	Duracion	4 h
Herramientas	Burp Suite Community Edition (Kali Linux) - OWASP ZAP (Kali Linux) - Firefox ESR + FoxyProxy - DVWA en Metasploitable 2	Nivel	Introductorio
Normativa	OWASP WSTG v4.2 - OWASP Top 10:2021 - ISO 27001:2022 A.8.25 (Ciclo de vida seguro) - ENS mp.sw.2	Prereq.	LAB-01, LAB-04
Objetivo	<i>Comprender el funcionamiento de un proxy de intercepcion web. Aprender a usar Burp Suite Community Edition y OWASP ZAP para interceptar trafico HTTP, descubrir rutas, detectar vulnerabilidades web y documentar hallazgos. Identificar las diferencias clave entre ambas herramientas y el caso de uso optimo de cada una.</i>		

1. CONCEPTOS PREVIOS: EL PROXY DE INTERCEPCION WEB

1.1 Que es un proxy de intercepcion HTTP

Un proxy de intercepcion web (también llamado intercepting proxy o man-in-the-middle proxy local) es una herramienta que se situa entre el navegador del auditor y el servidor web objetivo. Todo el trafico HTTP y HTTPS pasa por el proxy, que puede leerlo, modificarlo, repetirlo o bloquearlo antes de que llegue al servidor o al navegador.

Elemento	Sin proxy	Con proxy de intercepcion
Flujo de trafico	Navegador -> Servidor (directo)	Navegador -> Proxy (127.0.0.1:8080) -> Servidor
Visibilidad del auditor	No puede ver ni modificar las peticiones	Ve y puede modificar cada peticion y respuesta
Trafico HTTPS	Cifrado — el auditor no puede leerlo	El proxy descifra, permite inspeccion, y re-cifra (MITM)
Casos de uso	Navegacion normal de usuario	Auditoria de seguridad, pruebas de aplicaciones web, depuracion

i El proxy de intercepcion actua como un MITM (Man In The Middle) local y autorizado. Para HTTPS, el navegador debe confiar en el certificado del proxy — por eso es imprescindible instalar el certificado CA del proxy en el navegador. Sin este paso, el navegador mostrara un aviso de certificado invalido.

1.2 Arquitectura del entorno de laboratorio

Componente	Software	IP / Puerto	Funcion en el laboratorio
Maquina auditora	Kali Linux Purple	<IP_KALI>	Ejecuta Burp Suite y OWASP ZAP
Navegador del auditor	Firefox ESR + FoxyProxy	Proxy -> 127.0.0.1:8080	Envia el trafico a traves del proxy
Proxy de intercepcion	Burp Suite o ZAP	127.0.0.1:8080	Intercepta y permite modificar el trafico
Servidor objetivo	Metasploitable 2	<IP_META>:80	Aloja DVWA, Mutillidae, phpMyAdmin, Tomcat
Aplicacion web objetivo	DVWA (Damn Vulnerable Web App)	http://<IP_META>/dvwa	Target principal de las practicas

1.3 Diferencias fundamentales entre Burp Suite y OWASP ZAP

Antes de empezar a usarlas, es importante entender que filosofia tiene cada herramienta. Esto explica por que se usan de forma diferente y cuando conviene una u otra.

Aspecto	Burp Suite Community	OWASP ZAP
Filosofia de diseno	Herramienta de auditor manual: el control lo tiene el auditor, que decide que interceptar y como modificarlo	Herramienta de escaner automatico con capacidad de intercepcion: ZAP puede actuar de forma autonoma con minima intervencion
Modelo de uso principal	Analisis manual profundo: interceptar, entender, modificar, repetir peticion a peticion	Escaneo automatico rapido: spider + active scan desatendido, ideal para CI/CD y primeras evaluaciones

Licencia	Community Edition: gratuita pero con limitaciones. Professional: de pago (450 USD/ano)	100% gratuita y de codigo abierto (Apache License 2.0). Sin funcionalidades de pago.
Curva de aprendizaje	Alta: la interfaz es compleja y hay muchas opciones. Requiere practica para dominarla	Media: interfaz mas intuitiva. El Automated Scan asistido guia al usuario paso a paso
Automatizacion (Community)	Intruder limitado a 1 hilo en Community. Escaner activo no disponible en Community	Escaner activo completo, spider y fuzzer sin restricciones de velocidad
Extensibilidad	BApp Store: cientos de extensiones (muchas de pago)	Marketplace: extensiones gratuitas. ZAP-API para automatizar desde scripts
Integracion CI/CD	Limitada en Community. Full en Professional	ZAP Docker image oficial para pipelines DevSecOps
Comunidad y mantenimiento	PortSwigger (empresa comercial)	OWASP Foundation (proyecto comunitario activo)
Mejor para...	Auditoria manual profesional, CTFs, bug bounty	Evaluaciones rapidas, DevSecOps, introduccion a seguridad web

DIFF: Regla practica para elegir: si necesitas entender en profundidad como funciona una aplicacion y probar vulnerabilidades concretas de forma manual -> Burp Suite. Si necesitas un primer analisis automatico rapido o integrar en un pipeline de CI/CD -> OWASP ZAP. En una auditoria real, se usan ambas de forma complementaria.

2. CONFIGURACION DEL ENTORNO (AMBAS HERRAMIENTAS)

Antes de empezar con las tareas practicas, el entorno debe estar correctamente configurado. Esta seccion se realiza una sola vez al inicio del laboratorio y es valida para las dos herramientas.

Verificacion previa del entorno

PASO 0 Verificar conectividad con el objetivo [Kali Linux]

```
# Abrir terminal en Kali Linux Purple
ping -c 3 <IP_META>
# Verificar que el puerto 80 esta abierto
curl -I http://<IP_META>/dvwa/login.php
# Debe responder: HTTP/1.1 200 OK
# Si no responde, verificar que Metasploitable 2 esta arrancada
```

2.1 Configuracion de Firefox ESR con FoxyProxy

FoxyProxy es una extension de Firefox que permite cambiar rapidamente entre diferentes proxies o entre proxy activado/desactivado. Es imprescindible para trabajar con herramientas de intercepcion sin tener que modificar la configuracion del sistema cada vez.

PASO 1 Instalar y configurar FoxyProxy en Firefox [Kali Linux]

```
# Abrir Firefox ESR
firefox &
# Navegar a: https://addons.mozilla.org/es/firefox/addon/foxyproxy-standard/
# Clic en 'Anadir a Firefox' -> Confirmar instalacion
# FoxyProxy aparece en la barra de herramientas (icono de zorro)
```

PASO 2 Crear el perfil de proxy para Burp y ZAP (mismo puerto 8080) [Firefox + FoxyProxy]

```
Clic en icono FoxyProxy -> Options
Add New Proxy:
  Titulo: 'Burp / ZAP'
  Proxy Type: HTTP
  IP Address: 127.0.0.1
  Port: 8080
Clic en 'Save'
Para activar: clic en FoxyProxy -> seleccionar 'Burp / ZAP'
Para desactivar: clic en FoxyProxy -> 'Turn Off'
```

TIP: Tanto Burp Suite como ZAP usan por defecto el puerto 8080. Solo puede estar activo uno a la vez. Para cambiar de herramienta: cerrar la primera, abrir la segunda, ambas usaran el mismo perfil de FoxyProxy.

2.2 Configuracion de Burp Suite Community

Burp Suite viene preinstalado en Kali Linux. La primera vez hay que aceptar los terminos de uso y configurar el listener del proxy.

PASO 3 Arrancar Burp Suite y verificar el listener [Burp Suite]

```
# Desde menu de aplicaciones: Applications -> Web Application Analysis -> burpsuite
# O desde terminal:
burpsuite &
Aceptar terminos de uso -> 'I Accept'
Seleccionar: Temporary project -> Next
Seleccionar: Use Burp defaults -> Start Burp
Verificar: Proxy -> Options -> Proxy Listeners
```

Debe aparecer: 127.0.0.1:8080 [Running]
Si no aparece: Add -> 127.0.0.1 : 8080 -> OK

PASO 4 Instalar el certificado CA de Burp en Firefox (para HTTPS) [Burp Suite + Firefox]

Activar FoxyProxy -> perfil 'Burp / ZAP'
Navegar en Firefox a: http://burpsuite
(o directamente: http://127.0.0.1:8080)
Clic en 'CA Certificate' -> descargar cacert.der
Firefox: Menu -> Preferencias -> Privacidad y seguridad
-> Ver certificados -> Importar
-> Seleccionar cacert.der descargado
-> Marcar: 'Confiar en esta CA para identificar sitios web'
-> OK
Verificar: navegar a https://<IP_META> -> sin aviso de certificado

BURP: El certificado CA de Burp debe instalarse en el almacen de certificados del sistema operativo si se usa otra herramienta de analisis. En Firefox es suficiente con instalarlo en el navegador. Sin este certificado, Burp no puede interceptar trafico HTTPS: Firefox mostrara 'SEC_ERROR_UNKNOWN_ISSUER' en cada sitio HTTPS.

2.3 Configuracion de OWASP ZAP

OWASP ZAP tambien viene preinstalado en Kali Linux. Su configuracion inicial es mas guiada que Burp Suite gracias al asistente de inicio.

PASO 5 Arrancar OWASP ZAP y configurar el proxy [OWASP ZAP]

Desde menu: Applications -> Web Application Analysis -> owasp-zap
O desde terminal:
zapproxy &

Asistente de inicio: seleccionar 'No, I do not want to persist this session'
Verificar: Tools -> Options -> Network -> Local Servers/Proxies
Address: localhost | Port: 8080
Si esta en otro puerto, cambiar a 8080
Verificar: FoxyProxy activado en Firefox

PASO 6 Instalar el certificado CA de ZAP en Firefox [OWASP ZAP + Firefox]

ZAP Menu: Tools -> Options -> Network -> Server Certificates
Clic en 'Save' -> guardar como zap_ca.cer
Firefox: Menu -> Preferencias -> Privacidad y seguridad
-> Ver certificados -> Importar
-> Seleccionar zap_ca.cer
-> Marcar: 'Confiar en esta CA para identificar sitios web'
-> OK

ZAP: ZAP genera su propio certificado CA en cada instalacion. Al igual que con Burp, sin instalarlo en Firefox no podras interceptar trafico HTTPS. Si cambias de maquina o de instalacion, tendras que repetir este paso.

2.4 Verificacion conjunta del entorno

Antes de continuar, verifica que ambas herramientas estan correctamente configuradas:

Verificacion	Como comprobarla	Resultado esperado
Burp arrancado y escuchando	Proxy > Options > Proxy Listeners	127.0.0.1:8080 -> Running [verde]
ZAP arrancado y escuchando	Tools > Options > Network > Local Servers	localhost:8080 configurado

FoxyProxy configurado en Firefox	Icono FoxyProxy -> lista de proxies	Perfil 'Burp / ZAP' con 127.0.0.1:8080
Certificado Burp instalado	Firefox: navegar a https://<IP_META>	Sin aviso de certificado (con Burp activo)
Certificado ZAP instalado	Firefox: navegar a https://<IP_META>	Sin aviso de certificado (con ZAP activo)
DVWA accesible	http://<IP_META>/dvwa/login.php	Pagina de login de DVWA visible
DVWA en nivel LOW	DVWA Security -> Security Level: Low	Nivel LOW para maximizar la explotabilidad

3. BLOQUE A — BURP SUITE COMMUNITY EDITION

En este bloque aprenderas a usar las cuatro herramientas principales de Burp Suite Community: Proxy (intercepcion), Repeater (repeticion y modificacion manual), Intruder (automatizacion limitada) y Target > Site Map (mapa del sitio).

BURP: Asegurate de que Burp Suite esta activo y FoxyProxy apunta a 127.0.0.1:8080 antes de empezar. ZAP debe estar cerrado para evitar conflictos de puerto.

TAREA B1 — Interceptar y analizar el proceso de login de DVWA

Objetivo: entender el flujo de una peticion HTTP POST de login usando el Proxy de Burp Suite. Ver los parametros que se envian al servidor y como el servidor responde.

PASO 1 Activar la intercepcion en Burp Suite [Burp Suite]

Pestaña Proxy -> subpestaña Intercept
Boton 'Intercept is off' -> clic -> debe cambiar a 'Intercept is on' [naranja]
Ahora TODAS las peticiones quedaran bloqueadas hasta que las reenvies manualmente

PASO 2 Hacer login en DVWA y capturar la peticion [Firefox + Burp]

```
# En Firefox, navegar a:  
http://<IP_META>/dvwa/login.php
```

Rellenar el formulario:

Username: admin

Password: password

Clic en 'Login'

El navegador se queda cargando: Burp ha interceptado la peticion

PASO 3 Analizar la peticion POST interceptada [Burp Suite > Proxy > Intercept]

En Burp, pestaña Proxy > Intercept, verás la peticion HTTP completa:

Linea de peticion: POST /dvwa/login.php HTTP/1.1

Cabeceras: Host, Cookie, Content-Type, Content-Length...

Cuerpo (body): username=admin&password=password&Login=Login

Anota en tu informe los parametros que se envian en el body

Clic en 'Forward' para enviar la peticion al servidor

El navegador completa el login

Clic en 'Forward' para enviar el resto de peticiones (CSS, JS, imagenes...)

Cuando el login este completo, desactivar intercepcion: 'Intercept is on' -> 'off'

PASO 4 Explorar el HTTP History [Burp Suite > Proxy > HTTP History]

Pestaña Proxy -> subpestaña HTTP History

Ver todas las peticiones capturadas durante la navegacion

Clic en cualquier peticion para ver: Request (izquierda) y Response (derecha)

Filtrar por URL: clic en 'Filter' -> escribir 'dvwa' -> Apply

Identificar y anotar:

- El tipo de autentificacion (cookies de sesion: PHPSESSID)
- Las cabeceras de seguridad presentes o ausentes (X-Frame-Options, CSP...)
- El codigo de respuesta HTTP del login exitoso (302 Redirect o 200 OK?)

TAREA B2 — Repeater: modificar peticiones manualmente

El Repeater es la herramienta mas poderosa de Burp para la auditoria manual. Permite coger cualquier peticion del historial, modificarla y reenviarla al servidor cuantas veces quieras, analizando la respuesta a cada cambio.

PASO 5 Enviar una peticion al Repeater [Burp Suite > Proxy > HTTP History]

En HTTP History, localizar la peticion GET a /dvwa/vulnerabilities/sqli/
 (Navegar a esa pagina en Firefox primero si no aparece)
 Clic derecho sobre la peticion -> 'Send to Repeater'
 Ir a la pestaña 'Repeater' (ahora tiene un punto naranja indicando que hay contenido)

PASO 6 Probar SQL Injection manual desde el Repeater [Burp Suite > Repeater]

En Repeater, ver la peticion GET original (panel izquierdo):
 GET /dvwa/vulnerabilities/sqli/?id=1&Submit=Submit HTTP/1.1
 PRUEBA 1 — Peticion normal:
 No modificar nada -> clic 'Send' -> analizar la respuesta
 La respuesta debe mostrar el nombre de un usuario de DVWA
 PRUEBA 2 — Inyeccion basica (deteccion de SQLi):
 Cambiar id=1 por id=1' (anadir una comilla simple)
 Clic 'Send' -> Ver si la respuesta contiene un error SQL
 Anotar el error exacto (error_message de MySQL = SQLi confirmado)
 PRUEBA 3 — Extraer todos los usuarios:
 Cambiar id= por id=1'+OR+'1'='1
 Clic 'Send' -> Ver cuantos usuarios devuelve la respuesta
 PRUEBA 4 — UNION para extraer version de MySQL:
 id=1'+UNION+SELECT+user(),version()--+
 Clic 'Send' -> Ver la respuesta
 Documentar en el informe: cada payload, respuesta recibida y que confirma

BURP: El Repeater permite ver la respuesta completa del servidor incluyendo cabeceras HTTP y cuerpo HTML. El panel 'Render' muestra la respuesta renderizada como HTML, lo que facilita ver los datos extraidos. El panel 'Raw' es el mas util para analizar errores SQL.

TAREA B3 — Intruder: fuerza bruta de credenciales (DVWA Brute Force)

El Intruder automatiza el envio de multiples peticiones con variaciones en los parametros. En la version Community el ataque es mas lento (1 hilo), pero suficiente para el laboratorio.

PASO 7 Preparar el Intruder con la peticion de login [Burp Suite]

Navegar a http://<IP_META>/dvwa/vulnerabilities/brute/
 Activar Intercept -> clic en 'Login' con cualquier usuario/pass
 En la peticion interceptada, clic derecho -> 'Send to Intruder'
 En Intruder -> pestaña 'Positions'
 Attack type: seleccionar 'Sniper'
 Clic en 'Clear SS' para eliminar todas las marcas automaticas
 Seleccionar el valor del parametro 'password' (el texto entre = y &)
 Clic en 'Add SS' -> el valor queda marcado con SS password SS

PASO 8 Configurar el payload y lanzar el ataque [Burp Suite > Intruder > Payloads]

Pestaña 'Payloads':
 Payload type: Simple list
 Payload Options -> Add:
 password
 admin
 123456
 letmein
 master
 dragon
 O cargar fichero: Load -> /usr/share/wordlists/rockyou.txt (primeras 50 lineas)
 Clic en 'Start Attack'
 Ordenar resultados por 'Length' (respuestas de longitud diferente = exito)
 La respuesta correcta tendra una longitud diferente a las incorrectas
 Anotar: que contrasena funciono y como lo identificaste por la longitud

OJO: El Intruder en Community Edition esta limitado a 1 peticion por segundo. En Professional es ilimitado. Para ataques reales de fuerza bruta en red se usa Hydra (LAB-06). El objetivo aqui es entender el mecanismo, no la velocidad.

TAREA B4 — Target Site Map: mapear la estructura de DVWA

PASO 9 Generar el mapa completo de DVWA navegando por la aplicacion [Burp Suite + Firefox]

Desactivar Intercept: 'Intercept is off'

Con FoxyProxy activo (Burp escuchando), navegar por TODAS las paginas de DVWA:

- DVWA Security (cambiar a Low)
- Brute Force, Command Injection, CSRF
- File Inclusion, File Upload, Insecure CAPTCHA
- SQL Injection, SQL Injection (Blind)
- Weak Session IDs, XSS (DOM), XSS (Reflected), XSS (Stored)
- CSP Bypass, JavaScript
- phpinfo.php

Mientras navegas, Burp va construyendo el Site Map automaticamente

PASO 10 Analizar el Site Map generado [Burp Suite > Target > Site Map]

Ir a Target -> Site Map

Expandir el nodo de <IP_META>

Ver todas las rutas descubiertas con sus codigos de respuesta

Clic derecho sobre <IP_META> -> 'Engagement tools' -> 'Discover content'

Buscar en el sitemap rutas interesantes:

- /dvwa/phpinfo.php (informacion de PHP — dato critico)
- /phpmyadmin/ (phpMyAdmin accesible — riesgo alto)
- /mutillidae/ (otra app vulnerable)

Documentar en el informe las 5 rutas mas relevantes encontradas con su codigo HTTP

4. BLOQUE B — OWASP ZAP (ZED ATTACK PROXY)

En este bloque aprenderas a usar las herramientas principales de OWASP ZAP: el Spider (descubrimiento de contenido), el Active Scan (escaneo automatico de vulnerabilidades), el panel de Alertas y el Fuzzer. Cerrar Burp Suite antes de empezar.

ZAP: Cerrar Burp Suite antes de arrancar ZAP para evitar el conflicto de puerto 8080. FoxyProxy ya esta configurado y funciona con ambas herramientas al compartir el mismo puerto.

```
# Cerrar Burp Suite si esta abierto
pkill -f burpsuite 2>/dev/null
# Arrancar ZAP
zaproxy &
```

TAREA Z1 — Automated Scan: primer escaneo guiado de DVWA

El Automated Scan de ZAP combina un spider y un active scan en un solo flujo guiado. Es la forma mas rapida de obtener una vision general de las vulnerabilidades de una aplicacion web.

PASO 1 Configurar y lanzar el Automated Scan de DVWA [OWASP ZAP]

En ZAP, menu principal: Automated Scan (boton grande en pantalla de inicio)

O: Quick Start -> Automated Scan

URL to attack: http://<IP_META>/dvwa/

Clic en 'Attack'

ZAP realiza automaticamente:

1. Spider: rastrea todos los enlaces del sitio
2. Ajax Spider: rastrea contenido cargado por JavaScript
3. Active Scan: lanza pruebas de vulnerabilidades en todas las rutas

Esperar a que el progreso llegue al 100% (~10-15 minutos)

Durante el escaneo, observar el panel 'Alerts' que va llenandose

PASO 2 Analizar el panel de Alertas del Automated Scan [OWASP ZAP > Alerts]

Panel inferior -> pestaña 'Alerts'

Alertas clasificadas por nivel: High (rojo), Medium (naranja), Low (amarillo), Informational (azul)

Expandir las alertas de nivel High:

- SQL Injection
- Cross Site Scripting (Reflected)
- Command Injection
- Remote OS Command Injection

Para cada alerta High, clic en ella y documentar:

- Nombre de la alerta
- URL afectada
- Parametro vulnerable
- Evidencia (el payload que uso ZAP y la respuesta)
- Solucion recomendada por ZAP

Captura de pantalla del panel de alertas completo para el informe

ZAP: El Automated Scan de ZAP no requiere autenticacion previa. Las rutas de DVWA que requieren estar logueado pueden no estar completamente auditadas. Para un escaneo autenticado, usa el Context Manager con credenciales (Tarea Z3).

TAREA Z2 — Spider manual y analisis del sitemap

El Spider de ZAP puede ejecutarse de forma independiente sobre una URL concreta. Compara el sitemap generado por el Spider de ZAP con el generado por Burp en la Tarea B4.

PASO 3 Ejecutar el Spider sobre DVWA [OWASP ZAP]

Tools -> Spider
 Starting Point: http://<IP_META>/dvwa/
 Max Depth: 10
 Clic en 'Start Scan'
 Panel 'Spider' -> ver las URLs descubiertas en tiempo real
 Cuando termine (progreso 100%), ver el panel 'Sites' en el lado izquierdo
 Expandir el nodo <IP_META> -> ver la estructura completa del sitio
 Comparar con el Site Map de Burp Suite (Tarea B4):
 Anotar: tiene ZAP mas o menos URLs que Burp? Por que?

PASO 4 Ejecutar el AJAX Spider para contenido dinamico [OWASP ZAP]

Tools -> AJAX Spider
 (El AJAX Spider usa un navegador real para ejecutar JavaScript)
 Starting Point: http://<IP_META>/dvwa/
 Browser: Firefox Headless
 Clic en 'Start Scan'
 Observar como descubre rutas que el Spider tradicional no encontro
 Comparar los resultados de Spider vs. AJAX Spider en el panel Sites

TAREA Z3 — Escaneo autenticado con Context Manager

Para escanear correctamente las paginas de DVWA que requieren autenticacion (como SQL Injection, XSS, etc.) hay que enseñar a ZAP a autenticarse automaticamente. Esto se hace mediante los Contextos de ZAP.

PASO 5 Crear un contexto autenticado para DVWA [OWASP ZAP]

PASO A: Capturar el proceso de login navegando a traves de ZAP

Activar FoxyProxy -> navegar en Firefox a http://<IP_META>/dvwa/login.php
 Hacer login: admin / password
 ZAP captura el trafico de login en el panel Sites

PASO B: Crear el contexto

Sites panel -> clic derecho sobre http://<IP_META>/dvwa
 -> 'Include in Context' -> 'New Context'
 Nombrar el contexto: 'DVWA_autenticado'

PASO C: Configurar la autenticacion en el contexto

Sites -> clic derecho -> 'Context' -> seleccionar DVWA_autenticado
 -> Authentication:
 Method: Form Based Authentication
 Login URL: http://<IP_META>/dvwa/login.php
 Username param: username
 Password param: password
 Login indicator: 'Logout' (texto que aparece cuando el login es exitoso)
 -> Users -> Add User: admin / password

PASO D: Lanzar Active Scan con autenticacion

Clic derecho sobre <IP_META>/dvwa -> Active Scan
 Seleccionar Context: DVWA_autenticado
 User: admin
 Lanzar el escaneo

ZAP: El escaneo autenticado descubrira muchas mas vulnerabilidades que el escaneo sin autenticacion, porque puede acceder a todas las paginas del modulo de practicas de DVWA. Compara el numero de alertas High entre el Automated Scan (sin auth) y este Active Scan (con auth).

TAREA Z4 — Generar el informe de ZAP

PASO 6 Exportar el informe de vulnerabilidades de ZAP [OWASP ZAP]

Esperar a que el Active Scan haya completado al 100%

Menu: Report -> Generate Report

Template: Traditional HTML Report

File name: zap_report_dvwa.html

Guardar en: ~/lab04b/

Alternativamente, exportar en XML para procesamiento automatico:

Template: Traditional XML Report

File name: zap_report_dvwa.xml

Abrir el informe HTML en Firefox para revisar su contenido

El informe incluye: descripcion de cada vulnerabilidad, URL, evidencia y recomendacion

5. TAREA FINAL — ANALISIS COMPARATIVO Y DOCUMENTACION

Esta tarea integra los resultados de ambos bloques para producir el hallazgo documentado de la practica. El objetivo es que el alumno reflexione sobre cuando usar cada herramienta y como complementarlas en una auditoria real.

5.1 Comparativa de resultados obtenidos en el laboratorio

Rellena la siguiente tabla con los resultados reales obtenidos en este laboratorio:

Aspecto	Burp Suite Community	OWASP ZAP
Tiempo de configuracion (minutos)	___ minutos	___ minutos
Numero de URLs descubiertas	___ URLs (Site Map)	___ URLs (Spider + AJAX)
Vulnerabilidades High detectadas	No disponible (Community sin active scan)	___ alertas High
Vulnerabilidades Medium detectadas	No disponible (Community sin active scan)	___ alertas Medium
SQL Injection encontrado en	___ (manual, Repeater, Tarea B2)	___ (automatico, Tarea Z1/Z3)
XSS encontrado en	___ (manual, navegacion)	___ (automatico, Active Scan)
Facilidad de configuracion del proxy (1-5)	___	___
Facilidad de uso para primera vez (1-5)	___	___
Calidad del informe generado automaticamente	No genera informe automatico	HTML/XML con evidencia completa
Que encontro que la otra NO encontro	_____	_____

5.2 Tabla de decision: cuando usar cada herramienta

Aspecto	Burp Suite Community	OWASP ZAP
Objetivo de la auditoria	Elegir Burp Suite si...	Elegir OWASP ZAP si...
Profundidad vs. velocidad	Necesitas analizar una funcionalidad concreta en profundidad	Necesitas una vision general rapida de toda la aplicacion
Nivel de automatizacion	Prefieres el control manual de cada peticion	Quieres un primer analisis automatizado sin intervencion
Presupuesto	Tienes licencia Professional o trabajas solo con Community	El proyecto no tiene presupuesto para herramientas de pago
Integracion en CI/CD pipeline	No es practico (Community no tiene API completa)	ZAP tiene imagen Docker oficial y API REST para pipelines
Analisis de logica de negocio	Muy adecuado: el auditor controla cada paso del flujo	Menos adecuado: el escaner no entiende la logica del negocio

Formacion y aprendizaje	Mas complejo, requiere mas tiempo de aprendizaje	Mas intuitivo para empezar, asistente guiado de inicio
Evidencia para informe	Requiere capturar pantallas manuales	Genera informe HTML/XML automatico con toda la evidencia

5.3 Hallazgo documentado — plantilla comun para ambas herramientas

Documenta UN hallazgo encontrado con Burp Suite y UN hallazgo encontrado con OWASP ZAP usando la siguiente ficha:

Campo	Hallazgo 1 (Burp Suite — Repeater)	Hallazgo 2 (OWASP ZAP — Active Scan)
ID	H-BZ-01	H-BZ-02
Herramienta utilizada	Burp Suite Community — Repeater	OWASP ZAP — Active Scan
Tipo de vulnerabilidad	_____	_____
URL afectada	_____	_____
Parametro vulnerable	_____	_____
Payload utilizado	_____	_____
Respuesta del servidor	_____	_____
Evidencia (captura)	Captura Burp Repeater adjunta	Alerta ZAP con Request/Response adjunta
Severidad (CVSS estimado)	_____	_____
Referencia OWASP	_____	_____
Recomendacion	_____	_____

5.4 Reflexion: complementariedad de las herramientas

En una auditoria de seguridad web profesional, Burp Suite y OWASP ZAP no son alternativas excluyentes: son complementarias. El flujo de trabajo tipico en un proyecto real es el siguiente:

Fase de la auditoria	Herramienta recomendada	Motivo
1. Reconocimiento rapido inicial	OWASP ZAP	Spider + Ajax Spider generan el mapa completo de la aplicacion en minutos con minima configuracion
2. Primer escaneo de vulnerabilidades	OWASP ZAP	Active Scan automatico da una lista inicial de candidatos a vulnerabilidades en toda la aplicacion
3. Confirmacion y profundizacion manual	Burp Suite	Repeater permite confirmar cada vulnerabilidad identificada por ZAP y explorarla en profundidad
4. Analisis de logica de negocio	Burp Suite	El control manual del flujo es imprescindible para vulnerabilidades que el escaner no puede detectar (IDOR, broken auth, business logic flaws)
5. Fuerza bruta de parametros	Burp Intruder / Hydra	Intruder (Professional) o Hydra para ataques de diccionario sobre formularios
6. Generacion del informe	OWASP ZAP	El informe automatico HTML de ZAP es mas completo y rapido de producir que el manual de Burp Community

6. ENTREGABLE

6.1 Ficheros a entregar

Fichero	Contenido	Origen
informe_lab04b.pdf	Informe con hallazgos documentados (seccion 5.3) + tabla comparativa (5.2)	Elaborado en este lab
burp_history.xml	Exportar el HTTP History de Burp: Proxy > HTTP History > clic derecho > Save Items	Burp Suite
burp_sitemap.xml	Exportar el Site Map: Target > Site Map > clic derecho > Save selected items	Burp Suite
burp_repeater_sqli.png	Captura de pantalla del Repeater con el payload SQLi y la respuesta	Burp Suite — Tarea B2
burp_intruder_result.png	Captura de pantalla del resultado del Intruder con la contraseña encontrada	Burp Suite — Tarea B3
zap_report_dvwa.html	Informe completo HTML de ZAP con todas las alertas	OWASP ZAP — Tarea Z4
zap_sitemap.png	Captura del panel Sites de ZAP con el arbol del sitio completo	OWASP ZAP — Tarea Z2
tabla_comparativa.png	Captura de la tabla 5.1 rellena con los datos reales del laboratorio	Elaborado en este lab

```
# Empaquetar todos los ficheros del lab
cd ~/lab04b
zip -r LAB04b_[apellido]_[nombre].zip .
```

6.2 Estructura del informe

1. Portada con datos del alumno y fecha.
2. Tabla de configuracion del entorno verificada (seccion 2.4 completada).
3. Bloque Burp Suite: capturas de Intercept, HTTP History, Repeater (con payload SQLi) e Intruder (con resultado).
4. Bloque OWASP ZAP: captura del panel Alerts con todas las High/Medium, captura del sitemap y enlace al informe HTML generado.
5. Tabla comparativa 5.1 con datos reales del laboratorio.
6. Tabla de decision 5.2 completada con criterios propios.
7. Dos fichas de hallazgo completas (5.3): una por herramienta.
8. Reflexion personal (minimo 10 lineas): que herramienta te resulta mas util y por que, que limitaciones has encontrado en cada una, y como las combinarias en una auditoria real.

7. PREGUNTAS DE REFLEXION

- * El Repeater de Burp Suite te permite modificar manualmente cualquier parametro de una peticion HTTP. Explica por que esto es mas potente para detectar vulnerabilidades de logica de negocio que un escaner automatico como ZAP. Da un ejemplo concreto de un tipo de vulnerabilidad que Burp puede detectar y ZAP no puede, y por que.
- * OWASP ZAP esta desarrollado por la OWASP Foundation y es completamente gratuito y de codigo abierto. Burp Suite Professional cuesta aproximadamente 450 USD/ano por licencia. Desde la perspectiva de una empresa de auditoria con 5 auditores: realiza un analisis coste-beneficio. Cuando estaria justificada la inversion en Burp Professional frente a usar ZAP gratuitamente? Que funcionalidades especificas de Professional justifican el coste?
- * El OWASP WSTG v4.2 (Web Security Testing Guide) define metodologias especificas de prueba para cada categoria de vulnerabilidad web. Investiga: segun el WSTG, que tecnica recomienda para probar SQL Injection (WSTG-INPV-05)? En que parte de este laboratorio has aplicado esa tecnica? Identifica el test ID del WSTG correspondiente a las 3 vulnerabilidades que has documentado en tus hallazgos.
- * El ENS mp.sw.2 (proteccion de aplicaciones) exige que las aplicaciones web implementen controles de seguridad en el ciclo de vida del desarrollo. Basandote en los hallazgos que has documentado con Burp y ZAP en DVWA: si esta aplicacion estuviera en un sistema de una Administracion Publica de categoria BASICA del ENS, estaria en conformidad con el control mp.sw.2? Justifica tu respuesta con al menos dos hallazgos concretos de este laboratorio.
- * Compara los sitemaps generados por Burp Site Map (Tarea B4) y el Spider de ZAP (Tarea Z2) sobre la misma aplicacion DVWA. Tiene el mismo numero de rutas descubiertas? Por que pueden ser diferentes? Que factores determinan la completitud del descubrimiento de rutas en una aplicacion web real (Javascript dinamico, autenticacion, cabeceras de seguridad...)?

8. RUBRICA DE EVALUACION

Criterio	Insuficiente (0-4)	Suficiente (5-7)	Excelente (8-10)
Configuracion del entorno (15%)	Sin proxy configurado o herramienta no arranca	Proxy configurado en al menos una herramienta con captura basica	Ambas herramientas configuradas con certificados SSL instalados y captura verificada
Uso de Burp Suite — Proxy e intercepcion manual (30%)	Sin interceptar ninguna peticion	Intercepta y modifica al menos una peticion HTTP en Repeater	Intercepta, modifica y documenta peticiones en Proxy + Repeater + Intruder con analisis de la respuesta
Uso de OWASP ZAP — Spider y escaneo activo (30%)	Sin ejecutar spider ni escaneo	Spider ejecutado con sitemap generado	Spider + Active Scan completados con al menos 3 alertas documentadas con evidencia de pantalla
Analisis comparativo y recomendacion justificada (25%)	Sin comparativa o sin argumentacion	Comparativa superficial con diferencias mencionadas	Tabla comparativa completa con criterio de seleccion justificado segun el tipo de auditoria, OWASP WSTG y ENS mp.sw.2

i Este laboratorio complementa el LAB-04 original. Mientras que el LAB-04 cubre el uso avanzado de Burp Suite para ataques web especificos (SQLi, XSS, CMDi), este LAB-04b se centra en el uso basico de ambas herramientas como proxies de intercepcion y en entender sus diferencias conceptuales y practicas.

9. REFERENCIAS

Documentacion oficial de las herramientas

- * PortSwigger. Burp Suite Documentation — Getting Started. <https://portswigger.net/burp/documentation>
- * PortSwigger. Burp Suite Community Edition — Feature comparison. <https://portswigger.net/burp/communitydownload>
- * OWASP Foundation. OWASP ZAP — Getting Started Guide. <https://www.zaproxy.org/getting-started/>
- * OWASP Foundation. ZAP Full Scan. <https://www.zaproxy.org/docs/docker/full-scan/>

Estandares y metodologias OWASP

- * OWASP Foundation. Web Security Testing Guide v4.2 (WSTG). <https://owasp.org/www-project-web-security-testing-guide/>
- * OWASP Foundation. OWASP Top 10:2021. <https://owasp.org/Top10/>
- * OWASP Foundation. OWASP Testing Guide — WSTG-INPV-05: Testing for SQL Injection. https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/07-Input_Validation_Testing/05-Testing_for_SQL_Injection

Normativa

- * Real Decreto 311/2022 — ENS. Anexo II, control mp.sw.2: Proteccion de las aplicaciones informaticas. BOE num. 106, 2022.
- * ISO/IEC 27001:2022. Annex A, control A.8.25: Secure development life cycle. ISO, 2022.
- * ISO/IEC 27001:2022. Annex A, control A.8.29: Security testing in development and acceptance. ISO, 2022.